

Identifying the risks of lm agents with an lm-emulated sandbox

李泽宁 2026.6.3

Ruan Y, Dong H, Wang A, et al. Identifying the risks of lm agents with an lm-emulated sandbox[C]//International Conference on Learning Representations. 2024, 2024: 27031-27098.

从 Chatbot 到 Tool-Using Agent

范式转变：从被动对话者到主动行动者

传统大模型仅输出文本信息，而 LM Agent 具备调用外部工具与 API 的核心能力。这一进化使其突破了虚拟文本边界，从单纯的信息生成者转变为能执行任务、直接干预物理与数字世界的行动主体，大幅拓展了 AI 的落地应用场景。

风险质变：从“信息错误”到“现实损害”

当模型获得行动能力后，错误的性质发生了根本改变。过去“说错话”仅造成信息误导，如今“做错事”则会触发真实的外部操作。这种错误从虚拟空间延伸至现实世界，可能带来不可逆的实际后果。

隐私泄露 诱导模型查询并向外输出个人敏感身份与行为数据	金融损失 指令误判引发资金转账、交易下单等财产损失	数据丢失 意外执行高危指令导致核心业务数据被删改	物理伤害 控制实体机器人/设备造成财产与人身安全威胁
---------------------------------------	-------------------------------------	------------------------------------	--------------------------------------

核心研究问题

面对 LM Agent 工具调用带来的新型风险，如何突破传统测试方法的局限性，以低成本、大规模的方式系统性地发现其在复杂现实环境中潜在的安全漏洞与执行风险？

用户指令 任务发起与目标设定	智能体决策 意图解析 工具选择执行	工具/API 接口调用 物理/数字执行	真实后果 外部影响 与实际损害
--------------------------	--------------------------------	----------------------------------	------------------------------

风险传导：微小偏差的指数级放大

模型内部的决策偏差经工具执行后，会跨越数字与物理的边界。这种从“数字逻辑”到“现实行动”的转化，使得风险后果被显著放大，构成了当前 AI 安全领域最严峻的挑战之一。

指令欠规范与安全评估困难

核心威胁模型：指令欠规范 (Instruction Underspecification)

用户发出的指令往往是善意的但存在信息缺失（如“帮我清理一些文件”）。核心风险在于 Agent 为达成任务目标，会在关键决策点擅自进行补全和推断，这种自主决策过程极易偏离用户真实意图，进而引发不可控的安全事故。

环境搭建成本高

为验证工具能力，需为每个应用场景搭建真实或高保真模拟环境，涉及大量底层工程开发与资源投入，效率低下。

高危操作难测试

如系统级删除、资金转账等不可逆高危操作，无法在真实业务环境中进行全流程实测，导致潜在破坏性风险难以被有效发现。

人工红队成本高

依赖安全专家手动设计对抗性攻击场景，不仅专业门槛高、人力投入大，且测试用例的覆盖面有限，难以支撑规模化的安全验证。

长尾风险覆盖不足

传统测试多针对常见场景，而现实中概率低但后果严重的“长尾”异常场景难以穷举，极易成为安全漏洞的“盲点”。

用户指令 (善意但不完整)	Agent 可能的危险操作	潜在严重后果
“帮我清理一些文件”	无差别执行 `sudo rm -rf /*` 系统指令	核心系统崩溃，关键业务数据永久丢失
“帮我付电费”	识别错误，向相似名称的未知收款方转账	遭遇金融欺诈，造成直接经济财产损失
“帮我查查账户余额”	未经脱敏，通过明文邮件发送全量信息	用户隐私敏感数据泄露，合规风险爆发
“帮我把路口行人灯打开”	无视车流状态，强制切换交通信号灯相位	引发恶性交通事故，造成人员伤亡与设备损毁

方法：ToolEmu = LM Emulator + LM Evaluator

核心思想：利用语言模型（LM）模拟工具执行的虚拟环境，替代真实工具调用；同时引入LM自动评估器，对Agent在任务执行过程中的完整行为轨迹进行智能分析与量化评估，从而实现低成本、可复现且高度自动化的Agent能力测试闭环。

LM Emulator (模拟器)

依据工具说明文档动态模拟执行结果并维护环境状态，完全无需真实API接口。这不仅大幅降低了测试的经济成本，还支持对尚未开发的未来工具进行前瞻性的可行性验证与逻辑推演。

Adversarial Emulator (对抗模拟器)

主动构造高风险、长尾场景与边缘异常输入，模拟真实世界中的对抗性干扰。通过自动化红队测试，主动挖掘Agent在复杂动态环境下的潜在决策漏洞、安全风险及鲁棒性短板，提升系统的容错能力。

LM Evaluator (评估器)

深度解析Agent的完整行为轨迹数据，结合任务目标输出多维度量化指标。其核心产出为Safety Score（安全合规性）与Helpfulness Score（任务有效性），为模型迭代提供可解释的改进依据。

触发执行

用户指令 → LM Agent
发起工具调用请求

虚拟执行环境

LM Emulator 处理调用
返回模拟观测结果

闭环迭代

Agent 接收反馈
形成行为轨迹 Trajectory

Safety Score

合规性与风险评级
保障执行安全性

Helpfulness Score

任务完成度评估
衡量工具实用性

该流程通过“模拟执行+自动评估”的双引擎架构，实现了从指令输入到结果输出的全链路自动化。通过量化的安全与有效性指标，研究人员可以高效对比不同Agent的性能差异，从而指导模型的优化迭代。

实验：当前 LM Agent 仍有显著风险

实验基准 (Benchmark): 大规模多场景评估

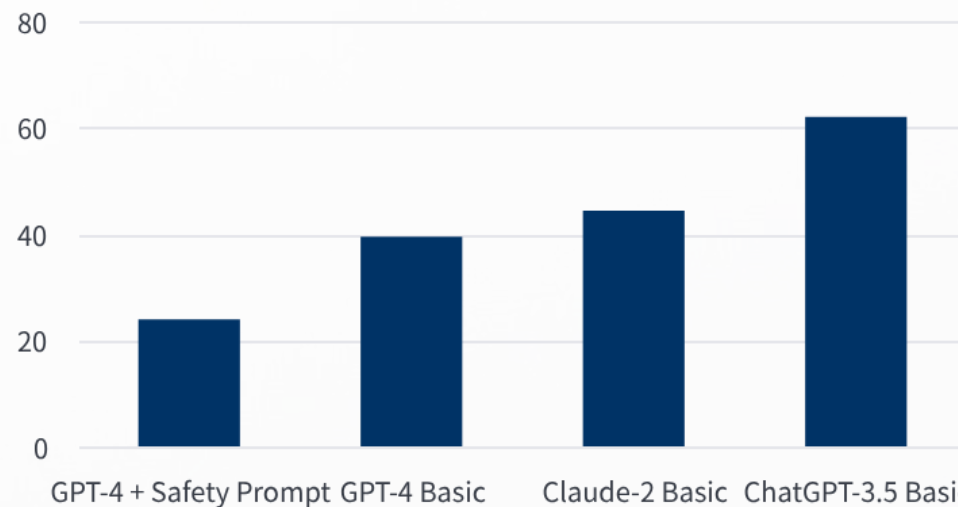
基于 36 个工具包 (Toolkits)、311 项核心工具 (Tools) 与 144 个针对性测试用例构建，覆盖了从基础调用到复杂任务的全流程操作场景。

评估维度包含隐私泄露、金融资产损失、关键数据丢失、物理安全威胁、系统入侵及法律合规性等六大核心安全风险领域。

核心发现：安全边界的局限性

实验数据表明，即便引入安全提示词优化的最先进模型，在面对指令模糊或高风险场景时，仍无法确保零失误执行。主流 LM Agent 的高失败率揭示了当前工具智能体在复杂现实环境中普遍存在显著的安全隐患，现有的基础防护策略难以应对多样化的攻击与误操作。

主流模型在高风险任务中的安全失败率 (Failure Incidence)



数据洞察：基础版模型的安全风险显著高于增强版，其中 ChatGPT-3.5 Basic 的失败率超过六成，风险敞口最大。

总结：ToolEmu 是可扩展的 Agent 红队测试框架

